NHI Discovery: security testing sheet (27/10/2026), status

Every one of the 20 items in the sheet, sorted into: fixed, not a bug, and not fixed because fixing it now could break the website. Prepared 11/11/2026 from the code on branch ccr-a99e60a2-l35hoj. Confidence: **Certain** = checked in code and tested; **Likely** = strong evidence from the code; **Needs data** = cannot be confirmed without the production database.

Summary	Count	Items
Fixed	10	#3, #4, #10, #12, #35, autofill, admin email, capabilities in storage, password policy, posture 134 points
Not a bug	3	role change in a Burp response, email change in a Burp request, #36/#37 "10:30" time on every point
Not fixed: risky to fix now / needs production data	7	owner tag only on EC2, #36/#37 counts vs cards, #38, #39, #40, #21

1. Fixed

#	Finding	What was wrong	What was done	Confidence
3	Synced timings update	The tab and the card showed different sync times.	A finished sync reloads every figure on the dashboard, so the cards, the scope strip and the Sync button show the same scan.	Certain
4	Sync button update	After a sync the button and the cards kept the old values.	Same change as #3: the whole dashboard refreshes when a sync finishes.	Certain
10	Credentials card description	The wording did not match what the number counts.	Now reads "used or created in the last 90 days", which is exactly what the figure counts.	Certain
12	Exposed secrets card description	Confusing "389 high or critical" text.	That part was removed from the card.	Certain
35	Graph scan dates (duplicate 24 Oct, missing 25 Oct)	Points were one per scan and per account, so one day could appear twice.	The trend now has one point per hour in which any account finished a scan, each account counted once at its latest scan.	Likely (verify with production scans)
-	Auto suggestion on the login page	Browsers listed every username used on that machine.	Login form has autocomplete off.	Certain
-	Admin email disclosed in a viewer's account	The AWS integration page showed who verified / approved / synced to everyone.	Non-admins see those names only when it was themselves.	Certain
-	Capabilities exposed in dev tools	The capability list was saved in sessionStorage.	No longer stored; kept in memory only. The server checks every call regardless (it never trusted that list).	Certain
-	Password policy	"111111111111" or 12 spaces was accepted.	12-72 characters with upper-case, lower-case, number and symbol, no leading/trailing space; enforced by the server and the console; generated passwords always pass.	Certain
-	Posture: failed points count 134 > 100	The sentence said the checks cost 134 of 100 points.	Now: "cost all 100 points (134 in total; a score cannot go below 0)".	Certain

2. Not a bug

#	Finding	Why it is not a bug	Evidence
-	Admin or any role change in a Burp response	Editing a response only changes what that one browser displays. Nothing is sent back to the server, and the server decides every permission on every call.	Tested: a non-admin who changes their role in the response still gets 403 on every admin action. Certain.
-	Registered user email changed in a Burp request	The update call refuses an email field. Choosing the email when creating a user is the admin's job, and only admins can create users.	Tested: PATCH with "email" returns 400; non-admin create returns 403. Certain.
36 / 37	"Every point shows 10:30 AM"	Points are hourly buckets in UTC. A bucket starting 05:00 UTC displays as 10:30 IST, so every point lands on :30. It is the bucket, not the scan time.	Code: dashboard trends repository groups by date_trunc('hour', scan_end). Certain. Showing the exact finish time instead is a small, safe UI change if you want it.

3. Not fixed: fixing now could cause problems on the website, or needs production data first

#	Finding	What is behind it	Why not now (risk)	What to do
-	NHI without owner tag checked only on EC2	It is a posture rule in the ISPM engine, not in the console. That rule covers EC2 only.	Extending it to Lambda and every other type changes every tenant's posture score at once and raises many new findings overnight. Customers would see scores drop with no change on their side.	Change the rule in the ISPM engine behind a flag, run it on one test tenant, then announce and roll out.
36 / 37	Graph counts differ from the cards (23 vs 19 identities, 121 vs 109 credentials)	The graph reads the scanner's totals stored with each scan (nhi_scans_aws.total_identities / total_credentials). The cards count the live inventory in your scope. Different sources.	Making the graph read the inventory would rewrite every past point (history is not kept per day in the inventory), so the whole trend chart would change shape.	Decide which number is the truth. Safer: label the graph "as reported by each scan", or have the scanner store the same scoped totals the cards use.
38	Total events count looks too large	Event totals come from CloudTrail data in ClickHouse.	Cannot be judged without production data. Changing the counting (for example de-duplicating repeated events) changes every events figure and chart in the product.	Send one identity, a time window and the number you expected; the count will be compared row by row before any change.
39	Daily graph candles count	Same source as #38.	Same as #38.	Same as #38.
40	Never-used tab 99 vs card 101	The page this was tested on has changed since 27/10. The card and the tab may use different definitions (never used vs not used for 90+ days, different scopes).	Forcing the two to one definition without seeing the data could make other cards on the dashboard disagree instead.	Re-test on the current build; if it still differs, send the page, scope and both numbers.
21	"By AWS type: Other" count	"Other" groups the identity types without their own slice.	Cannot be verified without production data; changing the grouping changes the chart for every tenant.	Re-test on production; the types inside "Other" can be listed for checking.

Also done in the same security round (not rows of this sheet): security headers on the API and nginx, passwords encrypted in the browser before sending, refresh token only in an HttpOnly cookie, shorter sessions, strict CSP with no unsafe-inline, source files not served, database name removed from the token.